Software Configuration Management Requirements for MediAssist

An Android medication-reminder app with a caregiver web dashboard

Name: Navy Lokai **Admission No.:** 672415

USIU-Africa | November 2026

Repository: https://github.com/NavyLokai/mediassist-scm

1. Application and Scope

MediAssist helps elderly users take medication on time. The system has three configurable parts: (1) an **Android client** (Java/Kotlin) that schedules reminders and logs doses, (2) a **Firebase backend** (Authentication, Firestore, Cloud Functions, Cloud Messaging) that syncs schedules and sends missed-dose alerts, and (3) a **caregiver web dashboard**. Because a faulty release could cause a missed or doubled dose, and the app stores health data protected under Kenya's Data Protection Act (2019), Software Configuration Management (SCM) must guarantee that every version is identified, every change is controlled and reviewed, and any release can be reproduced, traced or rolled back.

This document defines the SCM requirements across the four classic SCM functions (configuration identification, change control, status accounting and auditing), extended with build, release and software-supply-chain controls that current industry evidence shows are essential.

2. Industry Evidence (2024 Reports)

DORA – Accelerate State of DevOps Report 2024 (Google Cloud). Drawing on a survey of more than 39,000 professionals, the report confirms that high performers excel across all four delivery metrics: change lead time, deployment frequency, change failure rate and failed-deployment recovery time, and that teams weak in one tend to be weak in all four. It also found that AI adoption was associated with a 1.5% drop in throughput and a 7.2% drop in delivery stability, with analysts linking this to larger change batches. *Implication for MediAssist:* small, frequent, reviewed changes (SCM-03 to SCM-05) and tracking the four DORA metrics.

Sonatype – 10th Annual State of the Software Supply Chain Report 2024. Open-source components make up about 90% of modern software, consumption reached an estimated 6.6 trillion downloads, and open-source malware rose by 156% year on year. Even in 2024, 13% of Log4j downloads still contained the Log4Shell vulnerability. *Implication:* an Android app built on dozens of Gradle dependencies must pin, scan and inventory them (SCM-06, SCM-07).

3. SCM Requirements

ID	Area	Requirement	Rationale / source
SCM-01	Identification	Every configuration item (Kotlin/Java source, XML layouts, Gradle build scripts, Firebase rules, DB schema migrations, API contracts, test suites, design assets, this SCM plan) is stored and versioned in one Git repository with a documented folder structure.	Single source of truth; prerequisite for audits.
SCM-02	Identification	Releases follow Semantic Versioning (MAJOR.MINOR.PATCH); Android versionCode increments on every Play Store build; each release gets an annotated Git tag (e.g. v1.2.0).	Traceability from an installed app back to exact code.
SCM-03	Version control	Trunk-based workflow: protected main branch, short-lived feature branches (feature/, fix/, hotfix/) merged within 2 days; no direct pushes to main.	DORA 2024: small batches reduce change failure; AI tools tend to enlarge them.
SCM-04	Change control	All changes enter through pull requests linked to a GitHub Issue, with at least one peer review and passing CI before merge. Changes to reminder scheduling or caregiver alerts need two reviewers.	Missed or duplicated doses are a patient-safety risk.
SCM-05	Change control	AI-generated code is labelled in the PR description and reviewed like any other code; PRs over ~400 changed lines are split.	DORA 2024: AI adoption linked to 7.2% lower delivery stability.
SCM-06	Build	Builds are reproducible: Gradle wrapper and dependency versions pinned (version catalog + lock files); CI (GitHub Actions) builds, lints and runs unit + UI tests on every PR.	Same input always yields the same APK/AAB.

ID	Area	Requirement	Rationale / source
SCM-07	Supply chain	Automated dependency and vulnerability scanning (Dependabot, OWASP Dependency-Check) on every build; builds fail on critical CVEs; an SBOM (CycloneDX) is generated per release; licences are checked.	Sonatype 2024: ~90% of software is open source; 156% rise in OSS malware.
SCM-08	Security	No secrets in the repo: API keys and signing keystore live in GitHub Secrets / a vault; secret scanning and push protection enabled; release builds signed only in CI.	Leaked keys would expose patient data.
SCM-09	Release	Staged delivery: debug → internal test track → closed beta (caregivers) → staged Play Store rollout (10% → 50% → 100%) with one-click rollback to the previous tag.	Limits impact of a bad release on elderly users.
SCM-10	Environments	Separate dev, staging and production Firebase projects; configuration held as code; production uses no real patient data in testing.	Prevents test changes reaching live reminders; Kenya DPA 2019.
SCM-11	Status accounting	CHANGELOG.md and release notes generated from merged PRs; a release record lists tag, commit SHA, build number, SBOM and test results.	Answers 'what is running where?' at any moment.
SCM-12	Audit	Before each major release, a configuration audit confirms the shipped build matches the tagged source and that every change has an approved PR (functional and physical audit).	Required for accountability in health-related software.
SCM-13	Backup & recovery	Repository mirrored nightly; database backed up daily; restore tested each semester.	Recovery if GitHub access or data is lost.

4. Tooling and Workflow

- **Version control & hosting:** Git on GitHub with branch protection, required status checks, signed commits and CODEOWNERS for critical modules (scheduler, alerts, auth).
- **Issue & change tracking:** GitHub Issues and Projects; labels for bug, feature, security and accessibility; PR template with a testing and accessibility checklist (18 pt text, 4.5:1 contrast, 48×48 dp targets).
- **CI/CD:** GitHub Actions – lint, unit tests, Espresso UI tests, dependency scan, SBOM, signed AAB, and Play Console upload via Fastlane.
- **Versioning:** SemVer tags, auto-incremented versionCode, CHANGELOG generated from conventional-commit messages (feat:, fix:, docs:).

5. Measuring SCM Effectiveness

Following DORA, the team will track four metrics each sprint, with initial student-project targets: deployment frequency of at least one internal-track build per week; change lead time under 2 days from first commit to merge; change failure rate below 15% (releases needing a hotfix or rollback); and failed-deployment recovery time under 1 day using tagged rollbacks. Supply-chain health is measured by zero open critical CVEs at release and a complete SBOM for every tagged version.

6. Conclusion

For a health-related mobile app, SCM is not just version control: it is the mechanism that keeps reminders reliable and patient data safe. The 2024 DORA and Sonatype reports both point to the same priorities: small, reviewed and automated changes, and active management of third-party dependencies. The thirteen requirements above translate that evidence into concrete rules the MediAssist team can enforce through GitHub and CI from the first commit.

References

DORA / Google Cloud. (2024). *Accelerate State of DevOps Report 2024*. https://dora.dev/research/2024/dora-report/

Saunders, M. (2024, November 28). 2024 Accelerate State of DevOps Report shows pros and cons of AI. *InfoQ*. https://www.infoq.com/news/2024/11/2024-dora-report/

Sonatype. (2024). *10th Annual State of the Software Supply Chain Report*. https://www.sonatype.com/state-of-the-software-supply-chain/introduction

Linskens, A. (2024, November 21). Wrapping up a decade of insights from the State of the Software Supply Chain. *Sonatype Blog*. https://www.sonatype.com/blog/wrapping-up-a-decade-of-insights-from-the-state-of-the-software-supply-chain

Republic of Kenya. (2019). *Data Protection Act, No. 24 of 2019*. Kenya Gazette Supplement No. 181.